ATTORNEY SHIELD

ASI 2.0 - Native Android & iOS

Attorney Shield 2.0 - Backend Require

What the native apps need from the backend

revised 2026-08-12

Colour system: Attorney-Shield Color Scheme Review

Repository: samson-phillip/asi-claude

DRAFT FOR APPROVAL

Contents

From: mobile (Android + iOS) **Date:** 2026-08-12 (revised - see the correction below) **Status:** the apps now sign in against `gateway-dev` and reach Home with live data.

Correction to the earlier draft

An earlier version of this document claimed that registration, the document vault, family sub-accounts, notifications, OTP sign-in and token refresh had **no endpoints**. That was wrong, and the mistake was ours.

We had inferred the API surface from the operations `member-client` happens to use. The gateway has **238 queries and 297 mutations** with introspection enabled, and most of what we thought was missing is already there. Please ignore the earlier list.

What follows is based on the live schema at `https://gateway-dev.attorneyshield.io/query`.

---

1. Resolved - no longer blocking

Was	Now
Gateway URL unknown	`https://gateway-dev.attorneyshield.io/query`, found in `lfr-desktop/.env.example`
No dev member account	Supplied; sign-in verified end to end on Android
No token refresh	`refreshToken(input: RefreshTokenInput)` exists
No OTP sign-in	`requestLoginOtp(email, channel)` / `verifyLoginOtp(email, code, countryISO2)` exist
No registration endpoints	`register`, `createUserProfile`, `createUserAddress`, `setMemberPin`, `verifyMemberPin`, `memberPinStatus` exist
No document vault	`createUserDocument`, `deleteUserDocument`, `adminDocumentTypeList`, plus a request/finalize upload pattern
No family/plan	`addSubaccount`, `changeMembershipSeats`, `changeMembershipPlan`, `attachPaymentMethod`, `createSetupIntent`, billing history
No notifications	`notificationList`, `markNotificationRead`, `markAllNotificationsRead`, `clearNotifications`, `registerWebPush`
No emergency contacts	Full CRUD (`emergencyContactList`, `createEmergencyContact`, ...)

We can now build most of Phase 3 without waiting on you.

---

2. What we still need

2.1 Dev data is empty - BLOCKING our Home screen

Signed in as the test member, against `gateway-dev`:

```
adminIncidentTypeList(activeOnly: false) -> [] (no errors)
casesByUser(userID: <test member>) -> []
adminLanguageList -> 1 language
```

So Home correctly shows "No incident types are configured yet." - the app is behaving properly, there is simply nothing to show.

We need: incident types seeded on dev (the reference uses Traffic Stop, Auto Accident, Pedestrian Stop, Domestic, Test Call, Other), with translations, and ideally a case for the test member so jurisdiction and partner resolve rather than falling back to `DEV_DEFAULTS`.

Without this we cannot exercise the tile grid, the attorney chip row, or place a call with a real incident type.

2.2 An attorney online, to prove a video call - HIGH

`member-call` still returns `409 no attorney is available`, so **no real video call has ever connected.** Everything up to that point is proven: the Vonage SDK loads, reaches Vonage, and reports through our phase machine on both platforms.

We can see from `lfr-desktop` that going online is `commsUpsertAttorneyQueueMember(queueId, attorneyId, role, weight)`, and that there is a wider presence model (`attorneyPresence`, `attorneyActiveSession`, `attorneyDevice`).

We need one of:

- an attorney account we can use, plus confirmation that upserting a queue member is sufficient for the router to consider them available; or
- someone to run `lfr-desktop` for a scheduled window.

We have not put an attorney into the queue ourselves - it is a shared environment and that would make someone appear available for real calls.

2.3 Confirmations on shapes we are about to build against

Small, but each one is a guess otherwise:

1. `OtpChannel` - what are the enum values? (`SMS`, `EMAIL`, ...) The design reference describes a "one-time text code", so presumably SMS.
2. `verifyLoginOtp(..., countryISO2)` - is that required, and should it be the device region or the account's country?
3. **Does** `verifyLoginOtp` **return the same shape as** `login` (accessToken, refreshToken, userID, roles)?
4. `refreshToken` - what is the access-token lifetime, and does refresh rotate the refresh token?

5. `setMemberPin(userId, pin)` - the reference says the PIN's only job is ending a live session securely; it does not unlock the app. Is `verifyMemberPin` the intended gate for ending a call server-side?
6. **Casing is inconsistent and we will follow whatever each operation uses:** the gateway mixes `userID` (login, casesByUser) with `userId` (`setMemberPin`, `verifyMemberPin`), and comms REST uses `memberUserId`. Worth knowing before anyone adds a field.

2.4 Genuinely absent from the schema

Two areas returned **no matching operations at all**:

- **Situation preferences** (screens 13B, 13C, 27B) - the member's saved "three most common situations". Nothing matching `situation`, `preference` or `favourite`. Home currently shows the full incident list because there is nowhere to store a choice.
- **Trial and guest** (V1-V2, T1-T8, G1-G3) - nothing matching `trial` or `guest`. We need to know whether a guest is a real account with a role or a purely local state; that single answer decides the whole design.

2.5 Deep-link contract - HIGH

Screens 07 and T4 hand back to the app "with email pre-filled"; the reference never records the path. We currently accept `/app/return`, `/return-to-app` and `/app` on `attorney-shield.com` and `www.attorney-shield.com` with an `email` query parameter, all confined to one file.

Please do not design the link to carry a credential. We treat it as untrusted input - the email is a text-field prefill only, and there is a test asserting a link carrying `accessToken`/`userID`/`roles` yields nothing but the email. If the app needs to know what someone bought, we would rather ask after a real sign-in.

2.6 Domain verification files - HIGH (web task)

For the deep link to open the app silently, both hosts need `/.well-known/assetlinks.json` (Android, our signing SHA-256) and `/.well-known/apple-app-site-association` (iOS, our Team ID), for `com.app.attorney.shield`. We will send both once the release keystore exists.

---

3. One security note

`POST /api/vonage/video/member-call` **takes no authentication.** We are not designing around it, but as it stands anyone can place a call against any `organizationId`/`memberUserId` they can guess, and it routes to a real attorney.

Flagging rather than assuming it is known.

---

4. What we will ship as each lands

You give us	We ship
Incident types + a case seeded on dev	Home and the call flow verified against real data
An attorney online for a window	A proven end-to-end video call, both platforms
Answers to §2.3	OTP sign-in, token refresh, and registration screens 08-12
Situation-preference endpoints	The home screen's saved three, as designed
Trial/guest model decision	Those flows scoped
Deep-link contract	One-line change, then verified

Everything in §2.3 we can start immediately - the schema is there and the screens are specified.